



Vulnerability Assessment and Penetration Testing (VAPT) Report

Introduction

In today's digital environment, organizations rely heavily on interconnected systems and applications. These systems, if not properly secured, may contain vulnerabilities that can be exploited by attackers. Vulnerability Assessment and Penetration Testing (VAPT) is a structured approach used to identify, analyze, and remediate such security weaknesses.

The purpose of this assessment was to evaluate the security posture of a deliberately vulnerable virtual machine (Metasploitable 2) using open-source security tools. The assessment was conducted in a controlled lab environment using Kali Linux.

This project focuses on:

- Understanding security assessment methodologies
- Performing network and service enumeration
- Identifying vulnerabilities using scanning tools
- Evaluating risks using CVSS scoring
- Documenting findings in a structured professional format

The engagement was limited to the lab environment and did not involve any external or production systems.

Executive Summary

This report presents the findings of a Vulnerability Assessment and Penetration Testing (VAPT) conducted on a vulnerable virtual machine (Metasploitable 2). The objective was to identify security weaknesses using open-source tools and structured methodologies.

The assessment included network scanning, service enumeration, vulnerability analysis, and risk evaluation using CVSS scoring and a risk matrix approach.

During the practical phase, challenges were encountered while deploying OpenVAS, including feed synchronization delays, VPN-related network issues, and scanner initialization problems. These operational challenges were analyzed and documented.



The assessment identified multiple high-risk services exposed on the target system, including outdated FTP, SSH, and HTTP services.

Understanding Security Assessment

Security Assessment involves systematically identifying vulnerabilities in a system using structured frameworks such as NIST guidelines.

Types of Testing Covered:

Vulnerability Assessment:

Used tools like:

- Nmap
- OpenVAS

Purpose:

Identify known vulnerabilities without exploitation.

Pen Testing:

Simulated controlled attacks using:

- Metasploit Framework
- Manual enumeration techniques

Compliance Testing

Reviewed security posture against:

- CIS Benchmarks
- OWASP Top 10

VAPT Methodology Followed

The following structured approach was used:

Planning

Defined scope: Metasploitable VM IP

- Tools selected: Nmap, OpenVAS



Discovery

Performed:

`nmap -sC -sV 192.168.78.130`

Identified:

- Multiple open ports
- Outdated services
- Anonymous FTP access

Security Standards and Compliance

The assessment references:

- GDPR (Data protection principles)
- HIPAA (Healthcare data protection)
- ISO 27001 (Information security framework)
- OWASP Top 10 (Web vulnerabilities prioritization)

These standards guide vulnerability prioritization and remediation planning.

Practical Application

Environment Setup

- Kali Linux installed in VMware
- Metasploitable 2 deployed
- Network configured using NAT mode

Target IP identified using:

Ifconfig



5.2 Vulnerability Scanning

Nmap Scan

Command used:

```
nmap -sV 192.168.78.130
```

Findings:

- FTP (vsftpd 2.3.4)
- SSH (OpenSSH outdated version)
- HTTP (Apache vulnerable version)
- Multiple open ports

```
karan@karan: ~  
  
(karan@karan)-[~]  
$ ping 192.168.78.130  
PING 192.168.78.130 (192.168.78.130) 56(84) bytes of data.  
64 bytes from 192.168.78.130: icmp_seq=1 ttl=64 time=1.01 ms  
64 bytes from 192.168.78.130: icmp_seq=2 ttl=64 time=0.737 ms  
64 bytes from 192.168.78.130: icmp_seq=3 ttl=64 time=0.872 ms  
^C  
--- 192.168.78.130 ping statistics ---  
3 packets transmitted, 3 received, 0% packet loss, time 2005ms  
rtt min/avg/max/mdev = 0.737/0.874/1.014/0.113 ms  
  
(karan@karan)-[~]  
$ nmap -sV 192.168  
.Starting Nmap 7.95 ( https://nmap.org ) at 2026-02-26 03:03 EST  
Stats: 0:00:00 elapsed; 0 hosts completed (0 up), 1 undergoing Ping Scan  
Ping Scan Timing: About 100.00% done; ETC: 03:03 (0:00:00 remaining)  
  
(karan@karan)-[~]  
$ nmap -sV 192.168.78.130  
Starting Nmap 7.95 ( https://nmap.org ) at 2026-02-26 03:04 EST  
Nmap scan report for 192.168.78.130  
Host is up (0.0017s latency).  
Not shown: 977 closed tcp ports (reset)
```

Figure 1: Pinging And Nmap Command



```
(karan@karan)~$ nmap -sV 192.168.78.130
Starting Nmap 7.95 ( https://nmap.org ) at 2026-02-26 03:04 EST
Nmap scan report for 192.168.78.130
Host is up (0.0017s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec         netkit-rsh rexecd
513/tcp   open  login        OpenBSD or Solaris rlogind
514/tcp   open  shell?
1099/tcp  open  java-rmi     GNU Classpath grmiregistry
1524/tcp  open  bindshell    Metasploitable root shell
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc          VNC (protocol 3.3)
6000/tcp  open  X11          (access denied)
6667/tcp  open  irc          UnrealIRCd
8009/tcp  open  ajp13        Apache Jserv (Protocol v1.3)
8180/tcp  open  http         Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 00:0C:29:A4:00:AA (VMware)
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel
```

Figure 2: nmap findings

Risk Matrix (3x3 Model)

Likelihood	Impact	Risk
High	High	Critical
Medium	High	High
Low	Medium	Medium

Table 1: Risk metrix



Nmap Scan Analysis

Critical Services Identified

- **FTP port 21**

Service: vsftpd 2.3.4

This version of vsftpd is known to contain a backdoor vulnerability that allows remote command execution. This vulnerability is widely exploited and is considered Critical risk.

Risk Level: Critical

- **SSH port 22**

Service: OpenSSH 4.7p1 (Outdated)

Older versions of OpenSSH may contain known vulnerabilities and weak cryptographic configurations.

Risk Level: High

- **Telnet Port 23**

Service: Linux telnetd

Telnet transmits data in plaintext, including credentials. This makes it highly insecure.

Risk Level: High

- **HTTP port 80**

Service: Apache httpd 2.2.8

This is an outdated Apache version with multiple publicly known vulnerabilities.

Risk Level: High



- **Samba port 139 & 445**

Service: Samba 3.X – 4.X

Samba misconfigurations and outdated versions are vulnerable to remote exploitation.

Risk Level: High

- **MySQL port 3306**

Service: MySQL 5.0.51a

Outdated database server. Weak credentials may allow unauthorized access.

Risk Level: High

- **PostgreSQL port 5432**

Database service exposed externally. Improper access control could lead to data compromise.

Risk Level: Medium to High

- **VNC port 5900**

Remote desktop service exposed. May allow unauthorized graphical access if not secured.

Risk Level: Medium

- **Java RMI port 1099**

Java RMI services are frequently exploited for remote code execution in misconfigured environments.

Risk Level: High



Overall Risk Summary Table

Port	Service	Risk Level
21	FTP	High
23	Telnet	High
80	HTTP	High
139/445	Samba	High
3306	MySQL	High
5900	VNC	Medium

Table 2: Ports and its Risk Level

Overview of OpenVAS (Greenbone Vulnerability Manager)

OpenVAS (Open Vulnerability Assessment System), now known as Greenbone Vulnerability Manager (GVM), is an open-source vulnerability scanning and management framework used to detect security weaknesses in systems and networks.

It is integrated into Kali Linux and is widely used for automated vulnerability assessment in both academic and enterprise environments.

OpenVAS consists of multiple components:

- **gvmd (Greenbone Vulnerability Manager Daemon):** Manages vulnerability scan data and results.
- **ospd-openvas:** Scanner service responsible for running vulnerability tests.
- **gsad (Greenbone Security Assistant):** Web-based interface used to configure and manage scans.
- **NVT Feed (Network Vulnerability Tests):** Database of vulnerability detection scripts used during scanning.



What OpenVAS Can Do

OpenVAS provides the following capabilities:

1. Network Vulnerability Scanning
Detects open ports, running services, and associated vulnerabilities.
2. CVE Detection
Identifies known Common Vulnerabilities and Exposures (CVEs) in software and services.
3. CVSS Scoring
Assigns severity scores to vulnerabilities based on the Common Vulnerability Scoring System.
4. Report Generation
Generates detailed technical reports including severity levels, impact analysis, and remediation suggestions.
5. Compliance Checks
Supports checks against security standards and best practices.
6. Risk Prioritization
Categorizes vulnerabilities as Critical, High, Medium, or Low to assist in remediation planning.

Role of OpenVAS in This Assessment

In this VAPT exercise, OpenVAS was installed and configured to perform automated vulnerability scanning of the Metasploitable virtual machine.

Although operational challenges were encountered during feed synchronization and scanner initialization, the tool demonstrated the following key concepts:

- Importance of vulnerability database updates (NVT feeds)
- Dependency on proper service configuration
- Structured scan management process
- Automated CVE and CVSS-based vulnerability reporting

The experience provided practical exposure to enterprise-level vulnerability management tools and highlighted the importance of correct deployment and maintenance of security scanners.



```
(karan@karan)-[~]
$ sudo gvm-start
[sudo] password for karan:
[>] Please wait for the GVM services to start.
[>]
[>] You might need to refresh your browser once it opens.
[>]
[>] Web UI (Greenbone Security Assistant): https://127.0.0.1:9392

• gsad.service - Greenbone Security Assistant daemon (gsad)
  Loaded: loaded (/usr/lib/systemd/system/gsad.service; disabled; preset: disabled)
  Active: active (running) since Thu 2026-02-26 03:06:22 EST; 18ms ago
  Invocation: e352482936de44c0b2c7d6888448ad51
  Docs: man:gsad(8)
        https://www.greenbone.net
  Main PID: 7168 (gsad)
  Tasks: 1 (limit: 4410)
  Memory: 608K (peak: 1.8M)
  CPU: 11ms
  CGroup: /system.slice/gsad.service
          └─ 7168 /usr/bin/gsad - foreground - listen 127.0.0.1 - port 9392
```

Figure 3: Starting Openvas

New Target

Failed to create a new Target because the default Port List is not available. This issue may be due to the feed not having completed its synchronization. Please try again shortly.

Figure 4: Feed Sync Error

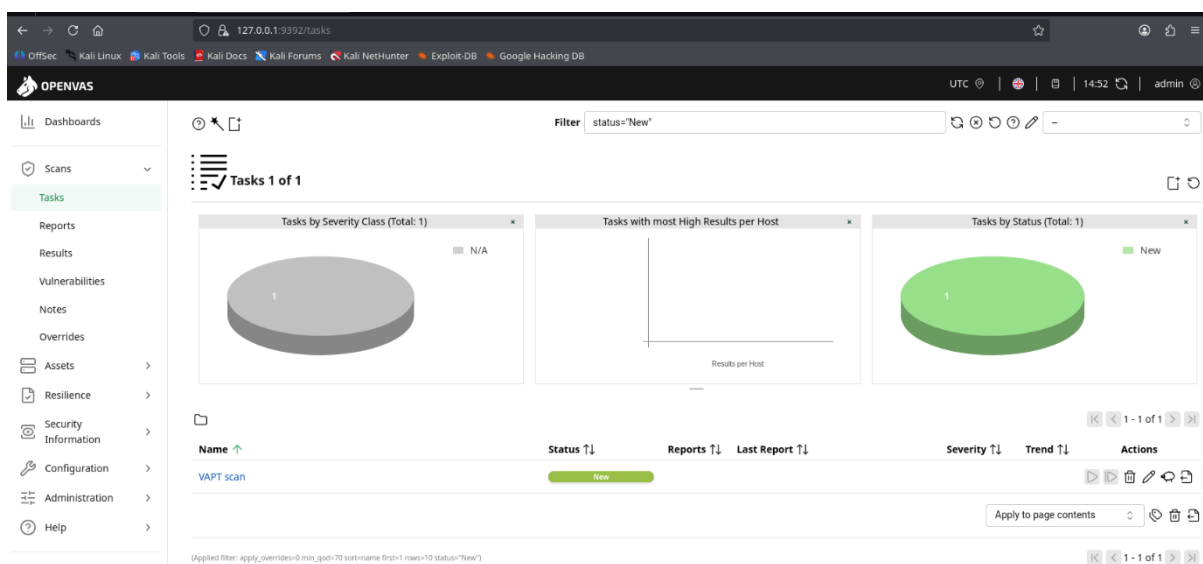


Figure 5: Task Dashboard

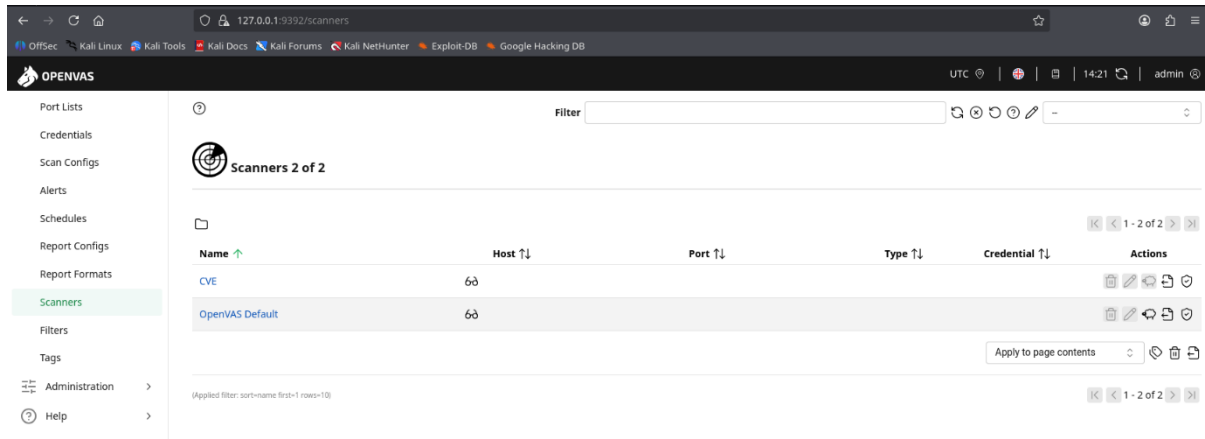


Figure 6: Scanners Dashboard

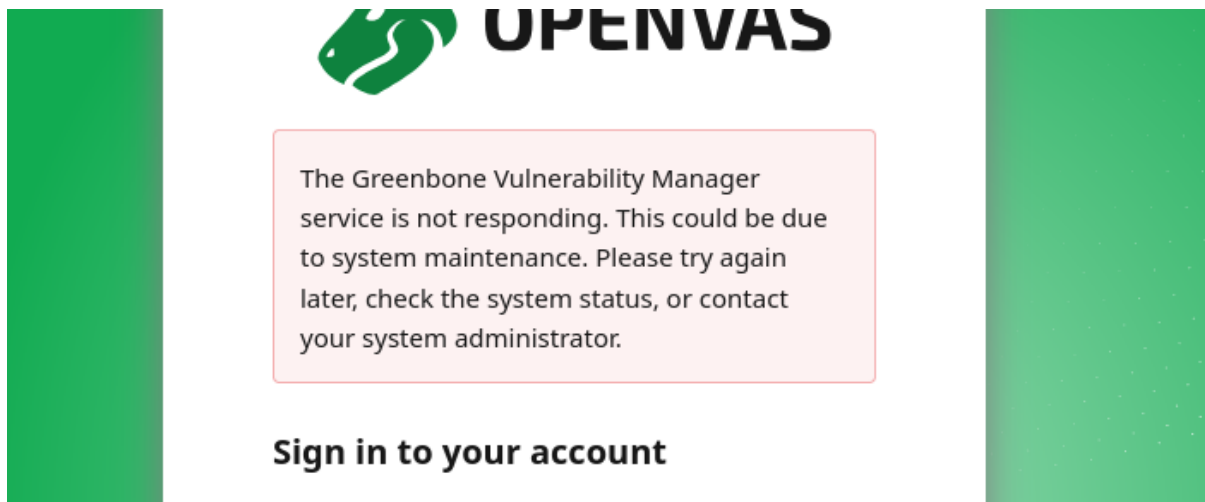


Figure 7: GVM Not Responding

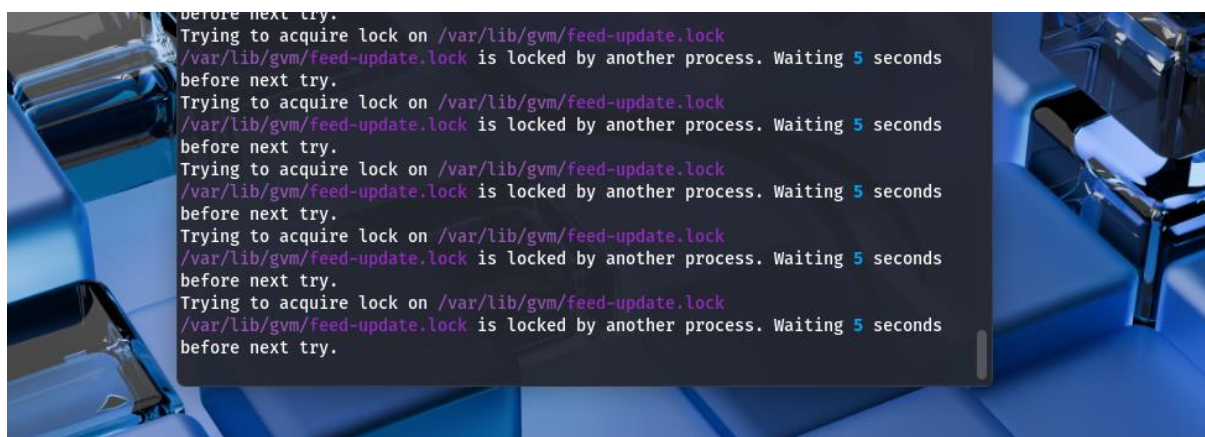


Figure 8: Feed Sync In Background

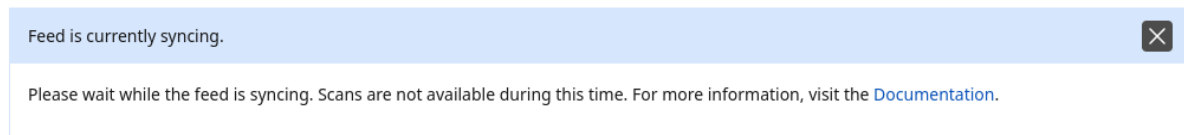


Figure 9: Feed Sync during Task Creation

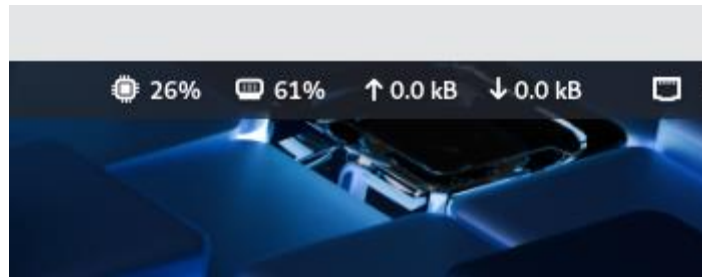


Figure 10: NO active network transfer

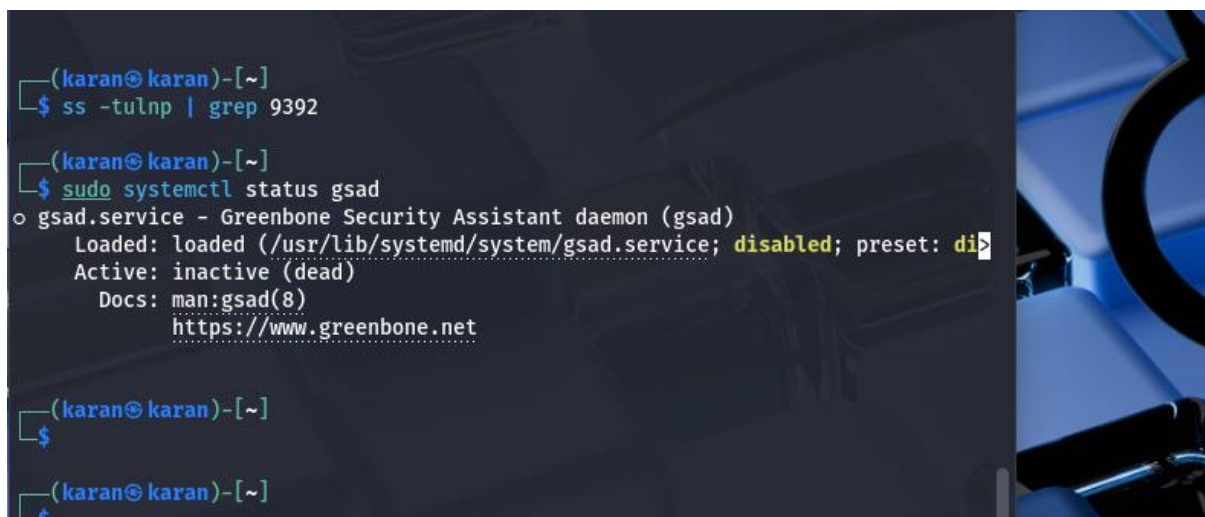


Figure 11: Inactive gsad service

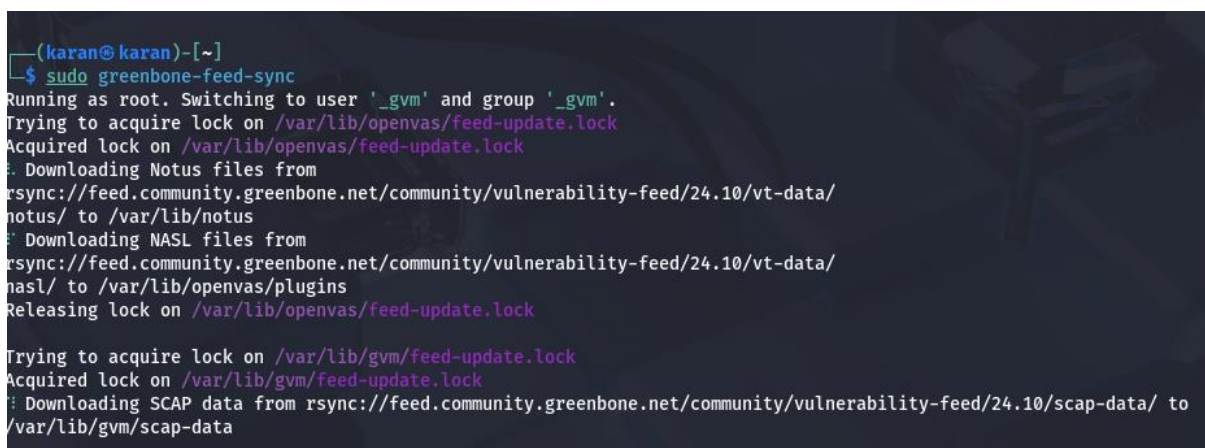


Figure 12: Force Sync Command



Key Learnings:

The VAPT exercise provided both theoretical and practical insights into security assessment methodologies. The following key learnings were achieved:

1. Understanding the difference between Vulnerability Assessment and Penetration Testing.
2. Practical exposure to network scanning using Nmap and service enumeration techniques.
3. Identification of open ports and outdated services in a lab environment.
4. Hands-on experience with risk prioritization using CVSS scoring.
5. Understanding the importance of structured VAPT phases (Planning, Discovery, Attack, Reporting).
6. Exposure to real-world operational issues such as scanner configuration errors and feed synchronization delays.
7. Improved troubleshooting skills related to Linux services, PostgreSQL, and systemctl management.
8. Appreciation of proper documentation and evidence collection for professional reporting.

This exercise strengthened technical analysis skills and enhanced understanding of vulnerability management processes.

Challenges Faced

During the practical implementation phase, several operational and technical challenges were encountered:

1. OpenVAS Feed Synchronization Delay
Initial feed synchronization required significant time and encountered lock file issues.
2. Feed Update Lock Error
The system displayed feed-update.lock errors due to incomplete synchronization processes.
3. Scanner Initialization Failure
The OpenVAS manager service (gvmd) failed to start properly due to database and runtime configuration issues.
4. Default Port List Unavailable
During target creation, the default port list was not accessible due to incomplete feed setup.
5. Play Button Inaccessible
The scan execution button was disabled because the scanner service was not fully operational.



6. VPN / Network Interference
VPN usage affected feed downloads and scanner communication in some instances.
7. Service Timeout Issues
The GVM Manager service experienced timeout errors requiring manual troubleshooting.

These challenges provided valuable hands-on experience in diagnosing and resolving security tool configuration problems.

Conclusion

The Vulnerability Assessment and Penetration Testing (VAPT) exercise was conducted in a controlled lab environment using Kali Linux and the Metasploitable virtual machine. The objective was to understand security assessment methodologies and apply practical vulnerability identification techniques using open-source tools.

An attempt was made to deploy OpenVAS for automated vulnerability scanning. However, operational challenges were encountered, including feed synchronization delays, scanner initialization issues, VPN-related connectivity concerns, and disabled task execution (Play button inaccessible). These challenges were documented and analyzed as part of the practical learning experience.

References

The following resources were consulted during the preparation of this report:

1. NIST Cybersecurity Framework – <https://www.nist.gov/cyberframework>
2. OWASP Web Security Testing Guide – <https://owasp.org/www-project-web-security-testing-guide/>
3. OWASP Top 10 – <https://owasp.org/www-project-top-ten/>
4. National Vulnerability Database (NVD CVSS Calculator) – <https://nvd.nist.gov/vuln-metrics/cvss>
5. Kali Linux Documentation – <https://www.kali.org/docs/>
6. Greenbone OpenVAS Documentation – <https://greenbone.github.io/docs/>
7. CIS Benchmarks – <https://www.cisecurity.org/cis-benchmarks>
8. Metasploit Framework Documentation – <https://docs.metasploit.com/>